

ISO 27001:2022

Readiness Self-Assessment Report

Company: Bad Co

Date: 01 June 2026

Overall Readiness: 100%

■ Good — Your organization shows strong ISO 27001 readiness.

Executive Summary

The following table shows the readiness score for each of the 7 Annex A domains. Scores are calculated as the percentage of controls within each domain that are adequately addressed based on your responses.

Domain	Score	Status	Coverage
Organizational Controls	100%	■	7/7
People Controls	100%	■	4/4
Physical Controls	100%	■	4/4
Technological Controls	100%	■	8/8
Asset Management	100%	■	3/3
Cryptography	100%	■	2/2
Incident Management	100%	■	2/2

Overall Score: 100%

Gap Analysis by Domain

For each domain, controls that were not adequately addressed are listed below with their description and suggested next steps.

■ Organizational Controls — Score: 100% (7/7 covered)

✓ All controls in this domain are adequately addressed.

■ People Controls — Score: 100% (4/4 covered)

✓ All controls in this domain are adequately addressed.

■ Physical Controls — Score: 100% (4/4 covered)

✓ All controls in this domain are adequately addressed.

■ Technological Controls — Score: 100% (8/8 covered)

✓ All controls in this domain are adequately addressed.

■ Asset Management — Score: 100% (3/3 covered)

✓ All controls in this domain are adequately addressed.

■ Cryptography — Score: 100% (2/2 covered)

✓ All controls in this domain are adequately addressed.

■ Incident Management — Score: 100% (2/2 covered)

✓ All controls in this domain are adequately addressed.

Full Q&A; Transcript

The complete list of all 30 questions and the responses provided during the assessment.

Q1. [Q01] Do you have a documented Information Security Policy?

Answer: we have a policy somewhere

Matched Controls: A.5.1

Q2. [Q02] Are roles and responsibilities for information security clearly defined?

Answer: not really defined

Matched Controls: A.5.2

Q3. [Q03] Do you have a process for managing information security risks?

Answer: no formal process

Matched Controls: A.5.8

Q4. [Q04] Is there a process for handling supplier/third-party security?

Answer: we handle suppliers informally

Matched Controls: A.5.19, A.5.20

Q5. [Q05] Do you conduct internal information security audits?

Answer: no audits conducted

Matched Controls: A.5.35

Q6. [Q06] Is there a business continuity plan that covers IT/data?

Answer: no BCP in place

Matched Controls: A.5.29, A.5.30

Q7. [Q07] Do you have a legal/compliance register for data protection laws?

Answer: we try to follow GDPR

Matched Controls: A.5.31, A.5.34

Q8. [Q08] Do you conduct background checks on new employees?

Answer: no background checks

Matched Controls: A.6.1

Q9. [Q09] Is security training provided to all staff?

Answer: no training provided

Matched Controls: A.6.3

Q10. [Q10] Do employees sign confidentiality/NDA agreements?

Answer: we have some agreements

Matched Controls: A.6.2

Q11. [Q11] Is there a process for offboarding employees (revoking access)?

Answer: offboarding is manual

Matched Controls: A.6.5

Q12. [Q12] Are server rooms / data centres physically secured?

Answer: basic lock on server room

Matched Controls: A.7.1, A.7.2

Q13. [Q13] Do you control visitor access to sensitive areas?

Answer: visitors sign in at reception

Matched Controls: A.7.3

Q14. [Q14] Is equipment protected against environmental threats?

Answer: no environmental protections

Matched Controls: [A.7.8](#)

Q15. [Q15] Do you have a clear desk and clear screen policy?

Answer: no clear desk policy

Matched Controls: [A.7.7](#)

Q16. [Q16] Do you use multi-factor authentication (MFA)?

Answer: MFA on some systems

Matched Controls: [A.8.5](#)

Q17. [Q17] Are access rights reviewed and revoked when no longer needed?

Answer: access reviews are rare

Matched Controls: [A.8.2](#), [A.8.3](#)

Q18. [Q18] Are all systems patched and updated regularly?

Answer: patching is irregular

Matched Controls: [A.8.8](#)

Q19. [Q19] Do you have antivirus / endpoint protection on all devices?

Answer: antivirus on some machines

Matched Controls: [A.8.7](#)

Q20. [Q20] Is network traffic monitored for threats?

Answer: no network monitoring

Matched Controls: [A.8.16](#)

Q21. [Q21] Do you have a Web Application Firewall (WAF) or similar?

Answer: no WAF

Matched Controls: [A.8.20](#), [A.8.21](#)

Q22. [Q22] Is data backed up regularly and tested for restore?

Answer: backups run daily

Matched Controls: [A.8.13](#)

Q23. [Q23] Do you conduct penetration tests or vulnerability scans?

Answer: no pentest done

Matched Controls: [A.8.8](#), [A.8.25](#)

Q24. [Q24] Do you maintain an inventory of all information assets?

Answer: asset inventory in spreadsheet

Matched Controls: [A.5.9](#)

Q25. [Q25] Is information classified according to sensitivity?

Answer: no classification scheme

Matched Controls: [A.5.12](#)

Q26. [Q26] Do you have a policy for secure disposal of media/devices?

Answer: we wipe disks sometimes

Matched Controls: [A.5.11](#), [A.7.14](#)

Q27. [Q27] Are laptops and mobile devices encrypted?

Answer: some laptops encrypted

Matched Controls: A.8.24

Q28. [Q28] Is sensitive data encrypted at rest and in transit?

Answer: TLS for external facing

Matched Controls: A.8.24, A.5.10

Q29. [Q29] Do you have an incident response plan?

Answer: no incident response plan

Matched Controls: A.5.24, A.5.25

Q30. [Q30] Are security incidents logged and reviewed after resolution?

Answer: incidents logged in email

Matched Controls: A.5.27, A.5.28